

PERTEMUAN 6

IMPLEMENTASI COBIT 2019

Study kasus : AUDIT TATA KELOLA TEKNOLOGI INFORMASI PADA Rumah Sakit XYZ MENGGUNAKAN *FRAMEWORK* COBIT 2019

RS XYZ merupakan rumah sakit terbesar di Kota A, telah mengimplementasikan SIM-RS untuk mempercepat pertumbuhan serta meningkatkan daya saing. Sebagai institusi yang berfokus pada pemberian pelayanan optimal kepada masyarakat, ketersediaan sistem informasi yang dapat mempermudah proses pelayanan sangatlah penting. Berdasarkan tujuan tersebut, RS XYZ membangun SIM-RS yang bertujuan untuk memenuhi, meningkatkan, dan mempermudah segala proses administratif terkait pelayanan pasien, manajemen informasi, akuntansi, dan pengadaan barang.

Namun, penggunaan teknologi informasi juga mengakibatkan meningkatnya risiko keamanan informasi, seperti ancaman peretasan, pencurian data, dan penyebaran malware. Untuk meminimalisir hal tersebut, sebuah audit keamanan perlu diterapkan

DOMAIN YANG DIGUNAKAN DALAM KASUS INI :
TABEL EVALUASI PROSES TEKNOLOGI

IT Domain	IT Process
Evaluate, Direct and Monitor	EDM03
Align, Plan and Organize	APO12, APO13, APO14
Deliver, Service and Support	DSS05

ADAPUN DESKRIPSI TIAP-TIAP PROSES TEKNOLOGI INFORMASI

Domain	Objective (Evaluate, Direct and Monitor)
EDM03	Ensured Risk and Optimation
Domain	Objective (Align, Plan and Organize)
APO12	Managed Risk
APO13	Managed Security
APO14	Managed Data
Domain	Objective (Deliver, Service and Support)
DSS05	Managed Security and Services

PENILAIAN KAPABILITAS PADA COBIT 2019 DIBAGI MENJADI 6 TINGKATAN

Level	Keterangan
0	Incomplete
1	Initial
2	Managed
3	Defined
4	Quantitative
5	Optimizing

Penilaian kapabilitas pada COBIT 2019 juga dapat dibantu dengan melakukan pemeringkatan pada aktivitas-aktivitas proses dengan pemeringkatan

Keterangan	Nilai Kapabilitas
N= NotAchieved	0-15%
P = Partially Achieved	15%-50%
L= Largely Achieved	50%-85%
F = FullyAchieve	85%-100%

Berikut List praktik yang terkait dengan setiap Tujuan Tata Kelola dan Manajemen dalam COBIT® 2019.

Objective ID	Objective	Objective Description	Objective Purpose Statement
EDM0301	Menilai pengelolaan risiko.	Memastikan selera risiko dan toleransi risiko perusahaan dipahami, diartikulasikan, dan dikomunikasikan, serta risiko terhadap nilai perusahaan yang terkait dengan penggunaan Teknologi Informasi (I&T) diidentifikasi dan dikelola	Pastikan bahwa risiko terkait I&T pada perusahaan tidak melebihi selera risiko dan toleransi risiko perusahaan, dampak risiko I&T terhadap nilai perusahaan diidentifikasi dan dikelola, dan potensi kegagalan kepatuhan diminimalkan.
EDM0302	Mengarahkan pengelolaan risiko.		
EDM0303	Memantau pengelolaan risiko.		
APO1201	Mengumpulkan data.	Terus-menerus mengidentifikasi, menilai, dan mengurangi risiko terkait I&T dalam batas toleransi yang ditetapkan oleh manajemen eksekutif perusahaan.	Mengintegrasikan manajemen risiko terkait I&T dengan manajemen risiko keseluruhan perusahaan (ERM) dan menyeimbangkan biaya dan manfaat dari manajemen risiko terkait I&T pada tingkat perusahaan
APO1202	Menganalisis risiko.		
APO1204	Mengartikulasikan risiko.		
APO1205	Menentukan portofolio tindakan pengelolaan risiko.		
APO1206	Menanggapi risiko.		
APO1301	Membentuk dan menjaga Sistem Manajemen Keamanan Informasi (ISMS).	Definisi, operasikan, dan pantau sistem keamanan informasi.	Menjaga dampak dan kejadian insiden keamanan dan privasi informasi dalam batas selera risiko perusahaan
APO1302	Menentukan dan mengelola rencana perlakuan risiko keamanan informasi dan privasi.		
APO1303	Memantau dan meninjau Sistem Manajemen Keamanan Informasi (ISMS).		
APO1401	Menentukan dan mengkomunikasikan strategi pengelolaan data dan peran serta tanggung jawab terkait	Capai dan pertahankan manajemen yang efektif atas aset data perusahaan di seluruh siklus hidup data, mulai dari pembuatan, pengiriman, pemeliharaan, hingga pengarsipan.	Memastikan pemanfaatan yang efektif dari aset data kritis untuk mencapai tujuan dan objektif perusahaan.
APO1404	Menentukan strategi kualitas data.		
APO1406	Memastikan pendekatan penilaian kualitas data.		
APO1407	Menentukan pendekatan pembersihan data.		
APO1409	Mendukung pengarsipan dan retensi data.		
APO1410	Mengelola pengaturan pencadangan dan pemulihan data.		
DSS0501	Melindungi dari perangkat lunak berbahaya.	Lindungi informasi perusahaan untuk menjaga tingkat risiko keamanan informasi yang dapat diterima oleh perusahaan sesuai dengan kebijakan keamanan. Tetapkan dan pertahankan peran dan hak akses keamanan informasi. Lakukan pemantauan keamanan.	Meminimalkan dampak bisnis dari kerentanan dan insiden keamanan informasi operasional.
DSS0502	Mengelola keamanan jaringan dan konektivitas.		
DSS0503	Mengelola keamanan endpoint.		

Practice ID	Practice Name	Practice Description
EDM0301	Menilai pengelolaan risiko.	Terus-menerus memeriksa dan mengevaluasi pengaruh risiko terhadap penggunaan teknologi informasi (TI) saat ini dan di masa depan dalam perusahaan. Pertimbangkan apakah tingkat risiko perusahaan sesuai dan pastikan risiko terkait nilai perusahaan yang berkaitan dengan penggunaan TI diidentifikasi dan dikelola.
EDM0302	Melakukan pengelolaan risiko secara langsung.	Mengarahkan pembentukan praktik pengelolaan risiko untuk memberikan keyakinan yang wajar bahwa praktik pengelolaan risiko TI sesuai dan risiko TI aktual tidak melebihi tingkat risiko yang ditetapkan oleh dewan direksi.
EDM0303	Memantau pengelolaan risiko.	Memantau tujuan utama dan metrik dari proses pengelolaan risiko. Tentukan bagaimana penyimpangan atau masalah akan diidentifikasi, dilacak, dan dilaporkan untuk perbaikan.
APO1201	Mengumpulkan data.	Mengidentifikasi dan mengumpulkan data yang relevan untuk memungkinkan identifikasi, analisis, dan pelaporan risiko terkait TI yang efektif.
APO1202	Menganalisis risiko.	Mengembangkan pandangan yang teruji terhadap risiko T & I aktual, sebagai dukungan dalam pengambilan keputusan risiko.
APO1204	Mengartikulasikan risiko.	Mengkomunikasikan informasi tentang keadaan terkini dari paparan dan peluang terkait TI secara tepat waktu kepada semua pemangku kepentingan yang diperlukan untuk tanggapan yang sesuai.
APO1205	Menetapkan portofolio tindakan pengelolaan risiko.	Mengembangkan pandangan yang teruji terhadap risiko TI aktual, sebagai dukungan dalam pengambilan keputusan risiko.
APO1206	Menanggapi risiko.	Menanggapi dengan tepat waktu pada peristiwa risiko yang terjadi dengan langkah-langkah efektif untuk membatasi besarnya kerugian.

Practice ID	Practice Name	Practice Description
APO1301	Membangun dan menjaga sistem pengelolaan keamanan informasi (ISMS).	Menetapkan dan menjaga sistem pengelolaan keamanan informasi (ISMS) yang menyediakan pendekatan standar, formal, dan berkesinambungan untuk pengelolaan keamanan dan privasi informasi. Pastikan bahwa sistem tersebut mendukung teknologi dan proses bisnis yang aman dan sejalan dengan persyaratan bisnis, pengelolaan keamanan perusahaan, dan pengelolaan privasi perusahaan.
APO1302	Menetapkan dan mengelola rencana perlakuan risiko keamanan informasi.	Menjaga rencana keamanan informasi yang menjelaskan bagaimana risiko keamanan informasi akan dikelola dan diselaraskan dengan strategi dan arsitektur perusahaan. Pastikan bahwa rekomendasi untuk meningkatkan keamanan didasarkan pada kasus bisnis yang disetujui, diimplementasikan sebagai bagian integral dari pengembangan layanan dan solusi, dan dioperasikan sebagai bagian integral dari operasi bisnis.
APO1303	Memantau dan meninjau sistem pengelolaan keamanan informasi (ISMS).	Menjaga dan secara teratur mengkomunikasikan kebutuhan dan manfaat dari perbaikan terus-menerus dalam keamanan informasi. Mengumpulkan dan menganalisis data tentang sistem pengelolaan keamanan informasi (ISMS), dan meningkatkan efektivitasnya. Memperbaiki ketidaksesuaian untuk mencegah terulangnya masalah.
APO1401	Menetapkan dan mengkomunikasikan strategi pengelolaan data dan peran serta tanggung jawabnya dalam organisasi.	Menetapkan bagaimana mengelola dan meningkatkan aset data organisasi, sesuai dengan strategi dan tujuan perusahaan. Mengkomunikasikan strategi pengelolaan data kepada semua pemangku kepentingan. Menetapkan peran dan tanggung jawab untuk memastikan bahwa data korporat dikelola sebagai aset penting dan strategi pengelolaan data diimplementasikan dan dipertahankan dengan cara yang efektif dan berkelanjutan.
APO1404	Menetapkan strategi kualitas data.	Menetapkan strategi terpadu dalam seluruh organisasi untuk mencapai dan mempertahankan tingkat kualitas data (seperti kompleksitas, integritas, akurasi, kelengkapan, validitas, keterlacakan, dan ketepatan waktu) yang diperlukan untuk mendukung tujuan bisnis.
APO1406	Memastikan pendekatan penilaian kualitas data.	Memberikan pendekatan sistematis untuk mengukur dan mengevaluasi kualitas data sesuai dengan proses dan teknik yang ditetapkan, serta berdasarkan aturan kualitas data.
APO1407	Menetapkan pendekatan pembersihan data.	Menetapkan mekanisme, aturan, proses, dan metode untuk memvalidasi dan memperbaiki data sesuai dengan aturan bisnis yang telah ditentukan.
APO1409	Mendukung penyimpanan arsip dan retensi data.	Memastikan bahwa pemeliharaan data memenuhi persyaratan organisasi dan peraturan untuk ketersediaan data historis. Memastikan bahwa persyaratan hukum dan peraturan untuk pengarsipan dan retensi data dipenuhi.
APO1410	Mengelola pengaturan cadangan dan pemulihan data.	Mengelola ketersediaan data penting untuk memastikan kelangsungan operasional.

Practice ID	Practice Name	Practice Description
DSS0501	Melindungi dari perangkat lunak berbahaya.	Menerapkan dan menjaga tindakan pencegahan, deteksi, dan perbaikan (terutama pembaruan keamanan terkini dan pengendalian virus) di seluruh perusahaan untuk melindungi sistem dan teknologi informasi dari perangkat lunak berbahaya (misalnya, malware, ransomware, virus, worm, spyware, spam).
DSS0502	Mengelola keamanan jaringan dan konektivitas.	Menggunakan tindakan keamanan dan prosedur pengelolaan terkait untuk melindungi informasi melalui berbagai metode konektivitas.
DSS0503	Mengelola keamanan ujung (endpoint security).	Memastikan bahwa ujung-ujung (seperti laptop, desktop, server, dan perangkat atau perangkat lunak seluler dan jaringan lainnya) diamankan pada tingkat yang sama atau lebih tinggi dari persyaratan keamanan dan privasi yang telah ditentukan untuk informasi yang diproses, disimpan, atau ditransmisikan

Gunakan toolkit COBIT 2019 RACI Analysis (Responsible, Accountable, Consulted, and Informed) pada domain EDM (Evaluate, Direct, and Monitor), APO (Align, Plan, and Organize), dan DSS (Deliver, Service and Support) untuk membantu mengidentifikasi tanggung jawab Pemangku kepentingan dengan Key Management Practice

Key Management Practices digunakan untuk pembuatan Matrik RACI

Key Management Practices	Practice
EDM0301	Evaluate risk management.
EDM0302	Direct risk management.
EDM0303	Monitor risk management.
APO1201	Collect data.
APO1202	Analyze risk.
APO1204	Articulate risk.
APO1205	Define a risk management action portfolio.
APO1206	Respond to risk.
APO1301	Establish and maintain an information security management system (ISMS).
APO1302	Define and manage an information security and privacy risk treatment plan.
APO1303	Monitor and review the information security management system (ISMS).
APO1401	Define and communicate the organization's data management strategy and roles and responsibilities.
APO1404	Define a data quality strategy.
APO1406	Ensure a data quality assessment approach.
APO1407	Define the data cleansing approach.
APO1409	Support data archiving and retention.
APO1410	Manage data backup and restore arrangements.
DSS0501	Protect against malicious software.
DSS0502	Manage network and connectivity security.
DSS0503	Manage endpoint security.

Hasil dari analisis RACI untuk memperjelas tanggung jawab dan keterlibatan setiap individu

Key Management Pratices	Direktur RS	Ka. Unit Instalasi IT	Unit Instalasi IT	Staff Admin	Staff Lain
EDM0301	C	R	R	R	I
EDM0302	A	A	R	R	I
EDM0303	A	R	R	R	I
APO1201	I	A	R	R	R
APO1202	A	R	C	C	C
APO1204	C	A	R	R	R
APO1205	A	A	R	R	R
APO1206	C	A	R	R	R
APO1301	C	C	R	A	I
APO1302	C	C	R	A	I
APO1303	C	C	R	A	I
APO1401	R	R	I	R	I
APO1404	A	C	R	R	R
APO1406	C	A	R	R	R
APO1407	C	C	R	R	I
APO1409	C	C	R	R	I
APO1410	C	C	R	A	I
DSS0501	R	R	R	R	R
DSS0502	C	C	R	A	R
DSS0503	C	C	R	A	R

DAFTAR PERTANYAAN EDM03

Jumlah Responden 6

No	Domain Proses	Pertanyaan	Level Kapabilitas	Skor				
				5	4	3	2	1
1	EDM0301	Memahami organisasi dan konteksnya terkait dengan risiko I&T	2					
2	EDM0301	Tentukan selera risiko organisasi, yaitu, tingkat risiko terkait I&T yang bersedia diambil perusahaan dalam mengejar tujuan perusahaan.	2					
3	EDM0301	Menentukan tingkat toleransi risiko terhadap selera risiko, yaitu penyimpangan sementara yang dapat diterima dari selera risiko.	3					
4	EDM0301	Menentukan sejauh mana keselarasan strategi risiko I&T dengan strategi risiko perusahaan dan memastikan selera risiko berada di bawah kapasitas risiko organisasi.	3					
5	EDM0302	Mengarahkan penerjemahan dan integrasi strategi risiko I&T ke dalam praktik manajemen risiko dan aktivitas operasional.	2					
6	EDM0302	Mengarahkan pengembangan rencana komunikasi risiko (mencakup semua tingkatan perusahaan).	2					
7	EDM0302	Implementasi langsung dari mekanisme yang tepat untuk merespons perubahan risiko dengan cepat dan segera melaporkan ke tingkat manajemen yang tepat, didukung oleh prinsip eskalasi yang disepakati (apa yang harus dilaporkan, kapan, di mana, dan bagaimana).	2					
8	EDM0303	Laporkan setiap masalah manajemen risiko kepada dewan atau komite eksekutif.	3					
9	EDM0303	Memantau sejauh mana profil risiko dikelola dalam batas selera dan toleransi risiko perusahaan.	3					
10	EDM0303	Pantau tujuan utama dan metrik tata kelola risiko dan proses manajemen terhadap target, analisis penyebab penyimpangan, dan mulai tindakan perbaikan untuk mengatasi penyebab yang mendasarinya.	3					

DAFTAR PERTANYAAN APO12

No	Domain Proses	Pertanyaan	Level Kapabilit	Skor				
				5	4	3	2	1
1	APO1201	Tetapkan dan pertahankan metode untuk pengumpulan, klasifikasi, dan analisis data terkait risiko I&T.	2					
2	APO1202	Rekam data terkait risiko I&T yang relevan dan signifikan di lingkungan operasi internal dan eksternal perusahaan.	2					
3	APO1203	Mengadopsi atau menentukan taksonomi risiko untuk definisi yang konsisten dari skenario risiko dan kategori dampak dan kemungkinan.	3					
4	APO1204	Catat data tentang peristiwa risiko yang telah menyebabkan atau dapat menyebabkan dampak bisnis sesuai dengan kategori dampak yang ditentukan dalam taksonomi risiko. Tangkap data yang relevan dari masalah terkait, insiden, masalah, dan investigasi.	3					
5	APO1205	Survei dan analisis data risiko I&T historis dan pengalaman kerugian dari data dan tren yang tersedia secara eksternal, rekan industri melalui log peristiwa berbasis industri, basis data, dan perjanjian industri untuk pengungkapan peristiwa umum.	2					
6	APO1206	Untuk kelas acara yang serupa, atur data yang dikumpulkan dan tandai faktor yang berkontribusi. Tentukan faktor umum yang berkontribusi di berbagai peristiwa.	2					

DAFTAR PERTANYAAN APO13

No	Domain Proses	Pertanyaan	Level Kapabilit	Skor				
				5	4	3	2	1
1	APO1301	Tentukan ruang lingkup dan batasan information security management system (ISMS) dalam kaitannya dengan karakteristik perusahaan, organisasi, lokasi, aset, dan teknologinya. Sertakan detail, dan justifikasi untuk, setiap pengecualian dari cakupan.	2					
2	APO1301	Tetapkan ISMS sesuai dengan kebijakan perusahaan dan konteks di mana perusahaan beroperasi.	3					
3	APO1302	Merumuskan dan memelihara rencana penanganan risiko keamanan informasi yang selaras dengan tujuan strategis dan arsitektur perusahaan. Pastikan bahwa rencana tersebut mengidentifikasi praktik manajemen dan solusi keamanan yang sesuai dan optimal, dengan sumber daya terkait, tanggung jawab, dan prioritas untuk mengelola risiko keamanan informasi yang teridentifikasi.	3					
4	APO1302	Mempertahankan sebagai bagian dari solusi arsitektur perusahaan inventarisasi komponen yang ada untuk mengelola terkait risiko keamanan.	3					
5	APO1303	Lakukan tinjauan rutin terhadap efektivitas ISMS. Termasuk memenuhi kebijakan dan tujuan ISMS dan meninjau praktik keamanan dan privasi.	2					
6	APO1303	Melakukan audit ISMS pada interval terencana.	3					

DAFTAR PERTANYAAN APO14

No	Domain Proses	Pertanyaan	Level Kapabilitas	Skor				
				5	4	3	2	1
1	APO1401	Menetapkan fungsi manajemen data dengan tanggung jawab untuk mengelola aktivitas yang mendukung tujuan manajemen data	2					
2	APO1402	Pastikan bahwa setiap istilah bisnis yang ditambahkan ke glosarium bisnis memiliki nama dan definisi yang unik.	2					
3	APO1403	Tetapkan dan ikuti proses manajemen metadata.	3					
4	APO1404	Tentukan strategi kualitas data dalam kolaborasi dengan pemangku kepentingan bisnis dan teknologi, disetujui oleh manajemen eksekutif, dan dikelola. Strategi harus memfasilitasi perpindahan dari kondisi saat ini ke kondisi target. Itu juga harus secara eksplisit selaras dengan tujuan bisnis dan strategi manajemen data organisasi	3					
5	APO1405	Mendefinisikan dan menstandarkan metodologi, proses, praktik, alat, dan templat hasil pembuatan profil data. Pastikan bahwa proses pembuatan profil dapat digunakan kembali dan dimanfaatkan di berbagai penyimpanan data dan repositori data bersama.	2					
6	APO1406	Lakukan penilaian kualitas data secara berkala, sesuai dengan frekuensi yang disetujui sesuai dengan kebijakan penilaian kualitas data. Pastikan bahwa tata kelola data menentukan kumpulan atribut kunci berdasarkan area subjek untuk penilaian kualitas data	2					
7	APO1407	Menetapkan dan memelihara kebijakan pembersihan data.	2					
8	APO1408	Memetakan dan menyelaraskan kebutuhan data konsumen dan produsen.	3					
9	APO1409	Pastikan bahwa kebijakan mengamankan pengelolaan riwayat data, termasuk retensi, penghancuran, dan persyaratan jejak audit.	3					
10	APO1410	Tetapkan jadwal untuk memastikan pencadangan yang benar dari semua data penting, dengan mempertimbangkan frekuensi akun, jenis pencadangan, keamanan, privasi, dan kriteria lainnya.	3					

DAFTAR PERTANYAAN DSS05

No	Domain Proses	Pertanyaan	Level Kapabilit	Skor				
				5	4	3	2	1
1	DSS0501	Instal dan aktifkan alat perlindungan perangkat lunak berbahaya di semua fasilitas pemrosesan, dengan file definisi perangkat lunak berbahaya yang diperbarui sesuai kebutuhan (secara otomatis atau semi otomatis).	2					
2	DSS0502	Izinkan hanya perangkat resmi yang memiliki akses ke informasi perusahaan dan jaringan perusahaan. Konfigurasi perangkat ini untuk memaksa entri kata sandi.	2					
3	DSS0503	Konfigurasi sistem operasi dengan cara yang aman	3					
4	DSS0504	Menjaga hak akses pengguna sesuai dengan fungsi bisnis, persyaratan proses, dan kebijakan keamanan. Menyelaraskan pengelolaan identitas dan hak akses ke peran dan tanggung jawab yang ditentukan, berdasarkan prinsip-prinsip yang paling tidak diistimewakan, perlu dimiliki dan perlu diketahui.	2					
5	DSS0505	Catat dan pantau semua titik masuk ke situs TI. Daftarkan semua pengunjung, termasuk kontraktor dan vendor, ke situs.	3					

Proses Selanjutnya Menghitung Capability Level EDM03

Proses	Pertanyaan	Level	SS 5	S 4	R 3	TS 2	STS 1	N	Skor	Mean	Kapability	Kapability
EDM0301	1	2	3	3	0	0	0	6	27	4.5	90%	Level 2
EDM0301	2	2	4	2	0	0	0	6	28	4.666666667	93%	94%
EDM0301	3	3	0	3	1	2	0	6	19	3.166666667	63%	
EDM0301	4	3	0	5	1	0	0	6	23	3.833333333	77%	
EDM0302	5	2	6	0	0	0	0	6	30	5	100%	
EDM0302	6	2	4	2	0	0	0	6	28	4.666666667	93%	Level 3
EDM0302	7	2	4	2	0	0	0	6	28	4.666666667	93%	71%
EDM0303	8	3	3	3	0	0	0	6	27	4.5	90%	
EDM0303	9	3	0	3	1	1	0	5	17	2.833333333	57%	
EDM0303	10	3	0	4	0	2	0	6	20	3.333333333	67%	

N = Jumlah Responden

Skor = Jawaban Responden X skala

Mean = Total Skor/ Jumla Responden

Skor maksimal = 30

$$\text{Skor EDM0301} = (3 \times 5) + (3 \times 4) + (0 \times 3) + (0 \times 2) + (0 \times 1) = 27$$

$$\text{Mean} = 27/6 = 4.5$$

$$\text{Kapability} = (27/30) \times 100\% = 90\%$$

$$\text{Skor EDM0301} = (4 \times 5) + (2 \times 4) + (0 \times 3) + (0 \times 2) + (0 \times 1) = 27$$

$$\text{Mean} = 28/6 = 4.6$$

$$\text{Kapability} = (27/30) \times 100\% = 93\%$$

$$\text{Skor EDM0301} = (0 \times 5) + (3 \times 4) + (0 \times 3) + (0 \times 2) + (0 \times 1) = 27$$

$$\text{Mean} = 19/6 = 3.1$$

$$\text{Kapability} = (27/30) \times 100\% = 63\%$$

$$\text{Skor EDM0301} = (0 \times 5) + (5 \times 4) + (0 \times 3) + (0 \times 2) + (0 \times 1) = 27$$

$$\text{Mean} = 23/6 = 4.8$$

$$\text{Kapability} = (27/30) \times 100\% = 77\%$$

$$\text{Skor EDM0302} = (3 \times 5) + (3 \times 4) + (0 \times 3) + (0 \times 2) + (0 \times 1) = 27$$

$$\text{Mean} = 27/6 = 4.5$$

$$\text{Kapability} = (27/30) \times 100\% = 100\%$$

$$\text{Skor EDM0302} = (4 \times 5) + (2 \times 4) + (0 \times 3) + (0 \times 2) + (0 \times 1) = 27$$

$$\text{Mean} = 28/6 = 4.6$$

$$\text{Kapability} = (27/30) \times 100\% = 93\%$$

$$\text{Skor EDM0302} = (0 \times 5) + (3 \times 4) + (0 \times 3) + (0 \times 2) + (0 \times 1) = 27$$

$$\text{Mean} = 19/6 = 3.1$$

$$\text{Kapability} = (27/30) \times 100\% = 93\%$$

$$\text{Skor EDM0303} = (0 \times 5) + (5 \times 4) + (0 \times 3) + (0 \times 2) + (0 \times 1) = 27$$

$$\text{Mean} = 23/6 = 4.8$$

$$\text{Kapability} = (27/30) \times 100\% = 90\%$$

$$\text{Skor EDM0303} = (3 \times 5) + (3 \times 4) + (0 \times 3) + (0 \times 2) + (0 \times 1) = 27$$

$$\text{Mean} = 27/6 = 4.5$$

$$\text{Kapability} = (27/30) \times 100\% = 57\%$$

$$\text{Skor EDM0303} = (4 \times 5) + (2 \times 4) + (0 \times 3) + (0 \times 2) + (0 \times 1) = 27$$

$$\text{Mean} = 28/6 = 4.6$$

$$\text{Kapability} = (27/30) \times 100\% = 67\%$$

$$\text{Kapability Level 2} = (90\% + 93\% + 100\% + 93\% + 93\%) / 5 = 94\%$$

$$\text{Kapability Level 3} = (63\% + 77\% + 90\% + 57\% + 67\%) / 5 = 71\%$$

Hasil Rating Proses EDM03						
Proses	Level 0	Level 1	Level 2	Level 3	Level 4	Level 5
Nilai	94%			71%		
Skala Penilaian	F			L		
Kapabilitas				Level3		
Keterangan						
N= NotAchieved	0-15%					
P = Partially Achieved	15%-50%					
L= Largely Achieved	50%-85%					
F = FullyAchieve	85%-100%					

Proses EDM03 (Ensuring Information Security Risk Management) telah mencapai tingkat 3 (Defined) dengan pencapaian aktivitas sebesar 71%. Namun, masih terdapat beberapa hambatan dalam pelaksanaan aktivitas proses tersebut, antara lain kurangnya pemantauan dan perbaruan profil risiko, serta evaluasi sistem yang belum optimal, seperti belum adanya penggunaan analisis risiko, belum mendapatkan sertifikasi keamanan, serta belum melakukan metode atau teknik dalam memantau keamanan sistem

APO12

Proses	Pertanyaan	Level	SS	S	R	TS	STS	N	Skor	Mean	Kapability	Rata2 per Level
			5	4	3	2	1					
APO1201	1	2	6	0	0	0	0	6	30	5	100%	Level 2
APO1202	2	2	6	0	0	0	0	6	30	5	100%	100%
APO1203	3	3	0	3	1	2	0	6	19	3.166666667	63%	
APO1204	4	3	0	4	2	0	0	6	22	3.666666667	73%	Level 3
APO1205	5	2	6	0	0	0	0	6	30	5	100%	68%
APO1206	6	2	6	0	0	0	0	6	30	5	100%	

$$\text{Skor APO1201} = (6*5) + (0*4) + (0*3) + (0*2) + (0*1) = 30$$

$$\text{Mean} = 27/6 = 5$$

$$\text{Kapability} = (30/30)*100\% = 100\%$$

$$\text{Skor APO1202} = (6*5) + (0*4) + (0*3) + (0*2) + (0*1) = 30$$

$$\text{Mean} = 28/6 = 5$$

$$\text{Kapability} = (30/30)*100\% = 100\%$$

$$\text{Skor APO1203} = (0*5) + (3*4) + (1*3) + (0*2) + (0*1) = 19$$

$$\text{Mean} = 19/6 = 3.1$$

$$\text{Kapability} = (19/30)*100\% = 63\%$$

$$\text{Skor APO1204} = (0*5) + (4*4) + (2*3) + (0*2) + (0*1) = 22$$

$$\text{Mean} = 23/6 = 3.6$$

$$\text{Kapability} = (22/30)*100\% = 73\%$$

$$\text{Skor APO1205} = (6*5) + (0*4) + (0*3) + (0*2) + (0*1) = 30$$

$$\text{Mean} = 27/6 = 5$$

$$\text{Kapability} = (30/30)*100\% = 100\%$$

$$\text{Skor APO1206} = (6*5) + (0*4) + (0*3) + (0*2) + (0*1) = 30$$

$$\text{Mean} = 28/6 = 5$$

$$\text{Kapability} = (30/30)*100\% = 100\%$$

$$\text{Kapability Level 2} = (100\%+100\%+100\%+100\%)/4 = 100\%$$

$$\text{Kapability Level 3} = (63\%+77\%)/2 = 68\%$$

Hasil Rating Proses APO12						
Proses	Level 0	Level 1	Level 2	Level 3	Level 4	Level 5
Nilai	100%			68%		
Skala Penilaian	F			L		
Kapabilitas				Level3		
Keterangan						
N= NotAchieved	0-15%					
P = Partially Achieved	15%-50%					
L= Largely Achieved	50%-85%					
F = FullyAchieve	85%-100%					

Proses APO12 (Risk Management) telah mencapai tingkat 3 (Defined), dengan pencapaian aktivitas sebesar 68%. Berdasarkan tabel di atas, masih terdapat beberapa kendala, seperti belum adanya dokumentasi mengenai pencatatan riwayat kejadian risiko (jika pun ada, belum dilakukan pengelompokan kejadian secara mendalam dan juga belum mengikuti standar industri yang ditetapkan), serta belum diperbaruinya skenario risiko TI secara teratur.

APO13

Proses	Pertanyaan	Level	SS	S	R	TS	STS	N	Skor	Mean	TCR	Rata2 per Level
			5	4	3	2	1					
APO1301	1	2	6	0	0	0	0	6	30	5	100%	Level 2
APO1301	2	3	0	3	2	1	0	6	20	3.333333333	67%	100%
APO1302	3	3	0	5	1	0	0	6	23	3.833333333	77%	Level 3
APO1302	4	2	6	0	0	0	0	6	30	5	100%	72%
APO1303	5	3	0	4	2	0	0	6	22	3.666666667	73%	

Skor APO1301 = $(6*5) + (0*4) + (0*3) + (0*2) + (0*1) = 30$ Mean = $30/6 = 5$ Kapability = $(30/30)*100\% = 100\%$

Skor APO1301 = $(0*5) + (3*4) + (2*3) + (1*2) + (0*1) = 20$ Mean = $20/6 = 3.3$ Kapability = $(20/30)*100\% = 67\%$

Skor APO1302 = $(0*5) + (5*4) + (1*3) + (0*2) + (0*1) = 23$ Mean = $23/6 = 3.8$ Kapability = $(23/30)*100\% = 77\%$

Skor APO1302 = $(6*5) + (0*4) + (0*3) + (0*2) + (0*1) = 30$ Mean = $30/6 = 5$ Kapability = $(30/30)*100\% = 100\%$

Skor APO1303 = $(0*5) + (4*4) + (2*3) + (0*2) + (0*1) = 22$ Mean = $22/6 = 3.6$ Kapability = $(22/30)*100\% = 73\%$

Kapability Level 2 = $(100\%+100\%)/2 = 100\%$

Kapability Level 3 = $(63\%+77\%+ 73\%)/3 = 68\%$

APO14

Proses	Pertanyaan	Level	SS 5	S 4	R 3	TS 2	STS 1	N	Skor	Mean	Kapability	Rata2 per Level
APO1401	1	2	3	3	0	0	0	6	27	4.5	90%	Level 2
APO1402	2	2	4	2	0	0	0	6	28	4.666666667	93%	94%
APO1403	3	3	0	3	1	2	0	6	19	3.166666667	63%	
APO1404	4	3	0	5	1	0	0	6	23	3.833333333	77%	
APO1405	5	2	6	0	0	0	0	6	30	5	100%	Level 3
APO1406	6	2	4	2	0	0	0	6	28	4.666666667	93%	73%
APO1407	7	2	4	2	0	0	0	6	28	4.666666667	93%	
APO1408	8	3	0	5	1	0	0	6	23	3.833333333	77%	
APO1409	9	3	0	5	1	1	0	7	25	4.166666667	83%	
APO1410	10	3	0	4	1	0	0	5	19	3.166666667	63%	

Skor APO0401 = $(3*5) + (3*4) + (0*3) + (0*2) + (0*1) = 27$

Skor APO0402 = $(4*5) + (2*4) + (0*3) + (0*2) + (0*1) = 28$

Skor APO0403 = $(0*5) + (3*4) + (1*3) + (2*2) + (0*1) = 19$

Skor APO0404 = $(0*5) + (5*4) + (1*3) + (0*2) + (0*1) = 23$

Skor APO0405 = $(6*5) + (0*4) + (0*3) + (0*2) + (0*1) = 30$

Skor APO0406 = $(4*5) + (2*4) + (0*3) + (0*2) + (0*1) = 28$

Skor APO0407 = $(4*5) + (2*4) + (1*3) + (0*2) + (0*1) = 28$

Skor APO0408 = $(0*5) + (5*4) + (1*3) + (0*2) + (0*1) = 23$

Skor APO0409 = $(0*5) + (5*4) + (1*3) + (1*2) + (0*1) = 25$

Skor APO04010 = $(0*5) + (4*4) + (0*3) + (0*2) + (0*1) = 19$

Mean = $27/6 = 4.5$

Mean = $28/6 = 4.6$

Mean = $19/6 = 3.1$

Mean = $23/6 = 3.6$

Mean = $30/6 = 5$

Mean = $28/6 = 4.6$

Mean = $28/6 = 4.6$

Mean = $23/6 = 3.8$

Mean = $25/6 = 4.1$

Mean = $19/6 = 3.1$

Kapability = $(27/30)*100\% = 90\%$

Kapability = $(28/30)*100\% = 94\%$

Kapability = $(19/30)*100\% = 63\%$

Kapability = $(23/30)*100\% = 77\%$

Kapability = $(30/30)*100\% = 100\%$

Kapability = $(28/30)*100\% = 94\%$

Kapability = $(28/30)*100\% = 94\%$

Kapability = $(23/30)*100\% = 77\%$

Kapability = $(25/30)*100\% = 83\%$

Kapability = $(19/30)*100\% = 63\%$

Kapability Level 2 = $(90\%+94\%+100\%+93\%+93\%)/5 = 94\%$

Kapability Level 3 = $(63\%+77\%+77\%+83\%+63\%)/5 = 73\%$

Hasil Rating Proses APO13						
Proses	Level 0	Level 1	Level 2	Level 3	Level 4	Level 5
Nilai			100%	72%		
Skala Penilaian			F	L		
Kapabilitas					Level3	

Proses APO13 (*Security Management*) telah mencapai tingkat 3 (*Defined*), dengan pencapaian aktivitas sebesar 72%. Namun, masih terdapat beberapa kendala yang perlu diperhatikan, seperti pelatihan pegawai terkait keamanan informasi jarang dilaksanakan.

Hasil Rating Proses APO14						
Proses	Level 0	Level 1	Level 2	Level 3	Level 4	Level 5
Nilai			94%	73%		
Skala Penilaian			F	L		
Kapabilitas					Level3	

Proses APO14 (*Continuity Management*) telah mencapai tingkat 3 (*Defined*), dengan pencapaian aktivitas sebesar 73%. Berdasarkan tabel di atas, masih terdapat beberapa kendala yang perlu diperhatikan. Salah satunya adalah penilaian kualitas data dilakukan secara jarang dan belum terjadwal secara berkala. Hal ini dapat dikarenakan oleh sinergi antara manajemen dan pegawai dalam mengembangkan kualitas data masih sangat kurang

DSS05

Proses	Pertanyaan	Level	SS	S	R	TS	STS	N	Skor	Mean	TCR	Rata2 per Level
			5	4	3	2	1					
DSS0501	1	2	6	0	0	0	0	6	30	5	100%	Level 2
DSS0502	2	2	6	0	0	0	0	6	30	5	100%	100%
DSS0503	3	3	0	4	1	1	0	6	21	3.5	70%	Level 3
DSS0504	4	2	6	0	0	0	0	6	30	5	100%	72%
DSS0505	5	3	0	4	2	0	0	6	22	3.666666667	73%	

$$\text{Skor APO1401} = (6*5) + (0*4) + (0*3) + (0*2) + (0*1) = 30$$

$$\text{Mean} = 30/6 = 5$$

$$\text{Kapability} = (30/30)*100\% = 100\%$$

$$\text{Skor APO1402} = (6*5) + (0*4) + (2*3) + (0*2) + (0*1) = 30$$

$$\text{Mean} = 20/6 = 5$$

$$\text{Kapability} = (30/30)*100\% = 100\%$$

$$\text{Skor APO1403} = (0*5) + (4*4) + (1*3) + (1*2) + (0*1) = 21$$

$$\text{Mean} = 23/6 = 3.5$$

$$\text{Kapability} = (21/30)*100\% = 70\%$$

$$\text{Skor APO1404} = (6*5) + (0*4) + (0*3) + (0*2) + (0*1) = 30$$

$$\text{Mean} = 30/6 = 5$$

$$\text{Kapability} = (30/30)*100\% = 100\%$$

$$\text{Skor APO1405} = (0*5) + (4*4) + (2*3) + (2*2) + (0*1) = 22$$

$$\text{Mean} = 22/6 = 3.6$$

$$\text{Kapability} = (22/30)*100\% = 73\%$$

$$\text{Kapability Level 2} = (100\%+100\%+100\%)/3 = 100\%$$

$$\text{Kapability Level 3} = (70\%+ 73\%)/3 = 72\%$$

Hasil Rating Proses DSS05						
Proses	Level 0	Level 1	Level 2	Level 3	Level 4	Level 5
Nilai	100%			72%		
Skala Penilaian	F			L		
Kapabilitas				Level3		
Keterangan						
N= NotAchieved	0-15%					
P = Partially Achieved	15%-50%					
L= Largely Achieved	50%-85%					
F = FullyAchieve	85%-100%					

Proses DSS05 (*IT Knowledge Management*) telah mencapai tingkat 3 (*Defined*), dengan pencapaian aktivitas sebesar 72%. Namun, berdasarkan tabel di atas, masih terdapat beberapa kendala yang perlu diperhatikan seperti Tingkat keamanan secara fisik yang masih terbilang rendah. Belum maksimalnya penggunaan *firewall* dan antivirus atau ala-alat keamanan di sekitar fisik server perlu diperhatikan, juga mengenai kebijakan di sekitar itu.

Proses	As is	To be	GAP
EDM03	3	4	1
APO12	3	4	1
APO13	3	4	1
APO14	3	4	1
DSS05	3	4	1

Selisih GAP ini menunjukkan keamanan pada Sistem Informasi Manajemen Rumah Sakit di RS XYZ masih berada pada tingkat 3 (*Defined*), dan belum mencapai tingkat kapabilitas yang diharapkan pada tingkat 4 (*Quantitative*). Selisih GAP pada penelitian ini adalah 1 tingkat di bawah kondisi yang diharapkan.

Rekomendasi Mitigasi

Dari hasil GAP analysis di atas, peneliti menyimpulkan beberapa rekomendasi mitigasi untuk dipertimbangkans ebagai bahan evaluasi RS XYZ dalam memperbaiki keamanan sistem informasi. Berikut dijelaskan rekomendasi mitigasi berdasarkan setiap proses

Rekomendasi Mitigasi

Pada **EDM03** *Ensuring Information Security Risk Management*, RS XYZ perlu melakukan dan meningkatkan penilaian tingkat resiko secara berkala agar rumah sakit dapat mengidentifikasi dan mengelola risiko-risiko yang dapat mengancam keamanan sistem informasi dengan lebih baik, serta mengambil tindakan yang tepat untuk melindungi data, menjaga kerahasiaan, integritas, dan ketersediaan informasi yang vital bagi operasional rumah sakit. RS XYZ. Melakukan pembaruan terhadap profil risiko saat ini agar tetap relevan dengan risiko-risiko yang ada. Beberapa hal yang dapat dilakukan dalam hal ini, seperti melakukan analisis risiko dengan analisis SWOT (*Strengths, Weaknesses, Opportunities, and Threats*), melakukan pemindaian keamanan sistem dengan vulnerability scanner, mempertimbangkan untuk mendapatkan sertifikasi keamanan seperti ISO 27001 atau HIPAA, melakukan penetration testing yang akan membantu mengidentifikasi celah keamanan yang dapat dimanfaatkan oleh penyerang, menerapkan prinsip keamanan dalam lapisan yang berbeda dengan Teknik Web Application Firewall (WAF) atau database firewall, melakukan implementasi Intrusion Detection System (IDS) atau Intrusion Prevention System (IPS), dan melakukan enkripsi data dengan menggunakan protokolenkripsi seperti SSL/TLS (*Secure SocketsLayer/Transport Layer Security*) untuk melindungi komunikasi data dan enkripsi penyimpanan data. Dengan melakukan peningkatan ini, organisasi dapat lebih efektif dalam mengelola risiko dan menjaga keamanan sistem informasi mereka.

Pada **APO12** Risk Management, RS XYZ perlu melakukan pencatatan dan peninjauan rutin terhadap insiden keamanan yang terjadi serta melakukan pengelompokan setiap insiden tersebut secara lebih komprehensif untuk memastikan keberlanjutan keamanan sistem dan mencegah gangguan baik dari dalam sistem maupun lingkungan sekitar. Hal ini dilakukan untuk memantau dan mengidentifikasi potensi celah atau gangguan keamanan yang dapat mempengaruhi sistem. Ini melibatkan pencatatan riwayat insiden keamanan, pelaporan kejadian yang mencurigakan, pengelompokan jenis-jenis insiden, serta melakukan audit keamanan secara rutin. Beberapa hal dapat dilakukan dalam hal ini, seperti melakukan implementasi *Information Security Management System (ISMS)* yang mengikuti standar industri seperti ISO27001, menggunakan sistem pelaporan insiden yang terpusat dan terotomatisasi untuk mencatat setiap insiden keamanan yang terjadi, menggunakan metode machine learning dengan algoritma klasifikasi atau sistem kategori yang sesuai untuk mengelompokkan insiden keamanan berdasarkan jenisnya, dan melakukan pemantauan keamanan dengan *Security Information and Event Management (SIEM)*. Dengan melakukan pencatatan dan peninjauan ini, dapat dilakukan tindak preventif yang tepat untuk menjaga keberlanjutan keamanan sistem

Pada **APO13** Security Management, RS XYZ perlu meningkatkan secara kuantitas dan kualitas mengenai pelatihan kepada pegawai terkait penggunaan sistem yang aman. Pegawai harus diberikan pelatihan, seperti bagaimana cara menggunakan sistem dengan aman, mengenali serangan phishing, memilih kata sandi yang kuat, dan menghindari tindakan yang dapat membahayakan keamanan sistem. Pelatihan ini membantu meningkatkan kesadaran dan pemahaman pegawai tentang pentingnya keamanan sistem informasi. Beberapa hal dapat dilakukan dalam hal ini, seperti mengikutsertakan pegawai dalam sertifikasi keamanan informasi, seperti CISSP, CISM, atau CompTIA Security+. Pelatihan ini berfokus pada pemahaman mendalam tentang praktik keamanan informasi dan persyaratan keamanan yang relevan, mengikuti pelatihan perlindungan data dan kepatuhan regulasi, semisalnya GDPR, pelatihan yang berfokus pada pemahaman tentang perlindungan data pribadi, mengikuti pelatihan sertifikasi ISO 27001, standar internasional untuk manajemen keamanan informasi, dan pelatihan keamanan jaringan dan infrastruktur, pelatihan yang akan memperkenalkan pegawai pada konsep dan praktik keamanan jaringan dan infrastruktur, termasuk proteksi firewall, deteksi intrusi, enkripsi, dan keamanan jaringan nirkabel.

Pada **APO14** Continuity Management, RS XYZ perlu meningkatkan komunikasi dan kolaborasi antara manajemen dan pegawai dalam mengembangkan kualitas data untuk memastikan bahwa data tetap berkualitas tinggi sepanjang waktu. Beberapa hal dapat dilakukan dalam hal ini, seperti membentuk tim khusus yang terdiri dari anggota manajemen dan pegawai yang bertanggung jawab untuk memantau dan meningkatkan kualitas data di rumah sakit. Tim ini harus memiliki representasi dari berbagai departemen yang terkait dengan pengelolaan data, seperti IT, medis, keperawatan, dan administrasi, menyelenggarakan rapat rutin antara manajemen dan pegawai untuk membahas isu-isu terkait pengelolaan data dan keamanan informasi, dan menetapkan metrik dan indikator kualitas data yang relevan, seperti akurasi, kelengkapan, kekonsistenan, dan kebaruan. Lakukan pemantauan rutin terhadap data yang dikumpulkan dan identifikasi masalah atau ketidaksesuaian. Dengan mengatasi kendala ini, organisasi dapat memastikan bahwa data yang mereka kelola dapat diandalkan, akurat, dan berkualitas tinggi, yang pada gilirannya akan mendukung pengambilan keputusan yang lebih baik dan 'operasional yang efisien

Pada DSS05 IT Knowledge Management, RS XYZ perlu melakukan peningkatan tingkat keamanan fisik server untuk mencegah akses yang tidak sah dan mengurangi risiko pencurian dan mengimplementasikan prosedur ketat dalam mengawasi tamu dan pegawai yang masuk ke dalam area server. Pemindaian data secara rutin pada komputer juga perlu dilakukan secara berkala untuk mencegah infeksi virus dan malware yang dapat membahayakan kerahasiaan, integritas, dan ketersediaan data. Aktivitas backup data penting juga perlu dilakukan secara berkala. Aktivitas ini merupakan langkah yang sangat penting dalam melindungi sistem informasi dari serangan malware dan memastikan kelangsungan bisnis. Hal ini memungkinkan pemulihan cepat, melindungi integritas data, dan memberikan perlindungan dalam situasi darurat atau serangan yang tidak terduga. Beberapa hal dapat dilakukan dalam hal ini, seperti pemasangan kamera CCTV yang memantau ruangan server dan area sekitarnya untuk memantau aktivitas yang mencurigakan, memberi batas akses fisik ke ruangan server hanya kepada personal yang membutuhkannya dan terapkan sistem kontrol akses seperti access card atau fingerprint, mengaktifkan dan mengatur pengumpulan log aktivitas server yang mencakup informasi seperti login, akses file, dan perubahan konfigurasi, memasang dan memperbarui firewall dan perangkat lunak antivirus yang handal untuk melindungi server dari ancaman malware dan serangan jaringan, menggunakan VPN untuk mengamankan koneksi jarak jauh ke server, sehingga data yang dikirimkan melalui jaringan tidak dapat dibaca oleh pihak yang tidak berwenang, dan melakukan pencadangan data secara teratur dan menyimpan salinan cadangan di tempat yang aman untuk memastikan ketersediaan data jika terjadi kejadian tak terduga atau bencana.